第 20 章 IP 安全

0. 学习目标总览

教材给出本章九个学习目标：

1. 简要介绍IP安全（IPsec）。
2. 解释传输模式和隧道模式的不同。
3. 理解安全关联的概念。
4. 解释安全关联数据库和安全策略数据库的不同。
5. 小结IPsec为出站数据包和入站数据包执行的流量处理功能。
6. 简要介绍封装安全净荷。
7. 讨论组合安全关联的替代方案。
8. 简要介绍因特网密钥交换（IKE）。
9. 小结适合IPsec使用的替代密码学套件。

本章主线是以策略选择流量，以 SA 保存参数，以 ESP 保护数据，再由 IKEv2 自动建立和更新密钥：

```
IP 数据包
  |-- SPD：决定 bypass / discard / protect
  |-- SAD：查找选定的安全关联
  |-- ESP：加密、完整性、数据源认证、反重放
  |     |-- 传输模式：保护 IP 净荷
  |     `-- 隧道模式：保护整个内部 IP 数据包
  `-- IKEv2：协商算法、认证对等方并建立 SA
```

1. 学习目标 1：IPsec 概述

IPsec 在 IP 层提供认证、保密性和密钥管理，因而可以保护远程登录、客户端/服务器、电子邮件、文件传输和 Web 等应用，而不要求每个应用单独实现安全功能。典型应用包括分支机构 VPN、远程访问、企业外连网/内连网和增强电子商务安全。

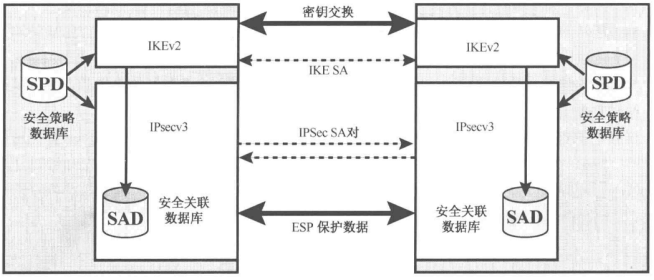


图 20.1　IPsec 架构

图 20.1 IPsec 架构

IPsec 文档体系包含架构（RFC 4301）、认证头部 AH、封装安全净荷 ESP、因特网密钥交换 IKE 和密码算法文档。AH 主要提供认证，ESP 提供加密或加密/认证组合，现代新应用通常优先使用 ESP。IPsec 服务包括访问控制、部分顺序完整性/反重放、无连接完整性、保密性、数据源认证和有限流量保密性。

2. 学习目标 2：传输模式与隧道模式

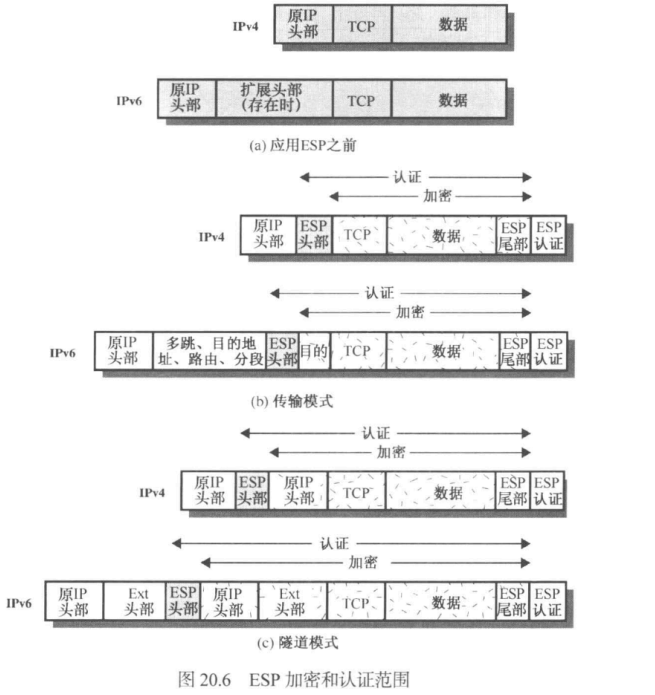


图 20.6　ESP 加密和认证范围

图 20.6 ESP 加密和认证范围

2.1 传输模式

传输模式主要（为上层协议提供保护）保护扩展到 IP 数据包的净荷，即 TCP/UDP 段或 ICMP 数据。ESP 头部插入 IP 头部与传输层段之间，ESP 尾部位于密文末端；传输层段和尾部加密，认证覆盖 ESP 头部和密文，但不保护原始 IP 头部。它适合支持 IPsec 的两台主机之间的端到端通信，开销较小，但仍可进行基于外部地址和长度的**流量分析**。

2.2 隧道模式

隧道模式把原始 IP 数据包（内部头部、净荷和 ESP 字段）作为新外部 IP 数据包的净荷。中间路由器只处理外部头部，内部源/目的地址和内容受到保护。它适合安全网关之间的站点到站点通信，也适合远程用户到企业网关的 **VPN（虚拟专用网）**；内部主机可以不实现 IPsec。

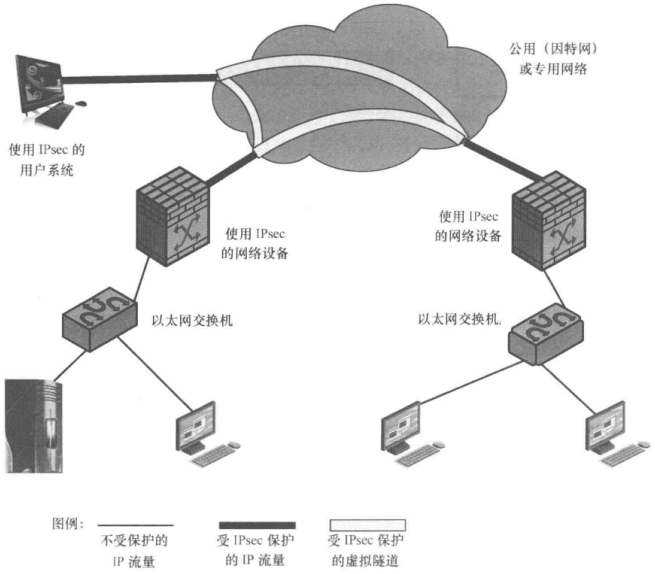


图 20.8　使用 IPsec 隧道模式实现的虚拟专用网示例

图 20.8 使用 IPsec 隧道模式实现的虚拟专用网示例

特性	传输模式	隧道模式
加密范围	IP 净荷和 ESP 尾部。	整个内部 IP 数据包。
外部地址	保留原始 IP 头部。	使用新的外部源/目的地址。
典型端点	主机到主机。	网关到网关或远程主机到网关。
流量隐藏	有限，外部头部仍可观察。	可隐藏内部地址和内部流量结构。

有关两个模式的辨析

ESP（封装安全净荷）的两种模式核心区别在于**保护范围**不同：传输模式仅保护IP数据包的**载荷（Payload）**，而隧道模式保护**整个IP数据包**

对于"隧道"的理解：
隧道模式的核心是"封装"。通过添加新IP头，原始数据包被完整地"包裹"起来。这个新IP头定义了隧道入口和出口的地址，使得封装后的数据包能在公共网络（如互联网）上从一端路由到另一端。在隧道终点，数据包被解封装，还原出原始IP包并转发给真正的目标。

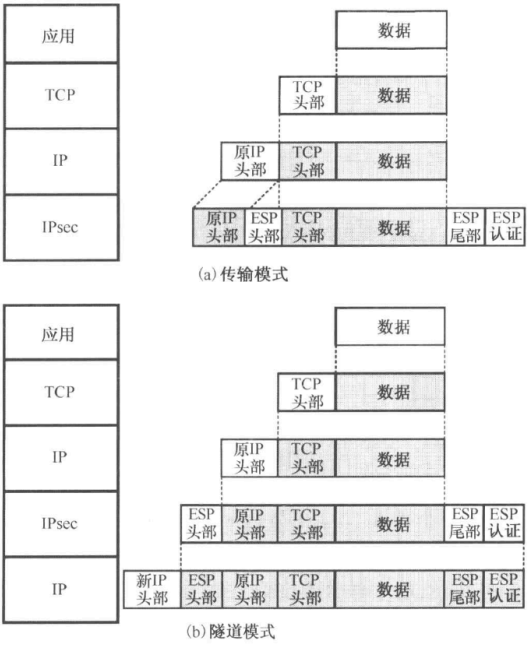


图 20.9　传输模式和隧道模式的协议架构

图 20.9 传输模式和隧道模式的协议架构

3. 学习目标 3：安全关联（SA）

安全关联是发送方和接收方之间的**单向逻辑连接**，规定该方向使用的安全服务、算法、密钥和生命周期。双向通信至少需要两个 SA。每个 SA 由三元组唯一确定：

1. **SPI**：本地有意义的 32 位安全参数索引，由 AH/ESP 头部携带。
2. **IP 目的地址**：SA 的目的端点，可以是主机或安全网关。
3. **安全协议标识**：说明是 AH 还是 ESP。

SA 还保存序号计数器、溢出标志、反重放窗口、AH/ESP 算法和密钥、生命周期、IPsec 模式及路径 MTU。SA 过期或序号达到上限时，应由新 SA 和新 SPI 替换，避免序号重用。

> **SA 理解**
>
> SA 是双方的单向逻辑连接，也就是说，如果需要双向安全交换，则需要建立两个安全连接。

4. 学习目标 4：SAD 与 SPD

4.1 安全关联数据库 SAD

> **补充**
>
> 每个 IPsec 实现中都有一个**名义**安全关联数据库（SAD），其定义与每个 SA 关联的参数。
>
> **名义**的含义：SAD 提供的功能必须出现在任何 IPsec 实现中，但提供功能的方法由实施者决定。

SAD 保存每个 SA 的运行参数：SPI、序号计数器、反重放窗口、认证/加密算法和密钥、生命周期、传输/隧道模式及路径 MTU。入站 ESP 根据目的地址、协议和 SPI 查找 SAD，以确定如何验证、解密和处理数据包。

4.2 安全策略数据库 SPD

SPD 将 IP 流量子集映射到 `bypass`、`discard` 或 `protect` 动作，并可指向一个或多个 SA。选择器包括远程/本地 IP 地址、下一层协议、操作系统用户标识以及本地/远程 TCP/UDP 端口。SPD 表达“哪些流量需要什么保护”，SAD 表达“已选 SA 的具体参数”。

表20.1 主机系统上的一个SPD例子

协议	本地IP	端口	远程IP	端口	动作	备注
UDP	1.2.3.10	500	*	500	绕过	IKE
ICMP	1.2.3.10	*	*	*	绕过	错误消息
*	1.2.3.10	*	1.2.3.0/24	*	PROTECT:ESP内连网模式	加密内联网流量
TCP	1.2.3.10	*	1.2.4.10	80	PROTECT:ESP内连网模式	加密到服务器
TCP	1.2.3.10	*	1.2.4.10	443	绕过	TLS：避免双重加密
*	1.2.3.10	*	1.2.4.0/24	*	抛弃	DMZ中的其他
*	1.2.3.10	*	*	*	绕过	因特网

这张表定义了 IPsec 的“开关”策略：**只对需要保护的内部流量（内联网、指定服务器）开启加密，对已加密的 HTTPS 和无意义的 ICMP/IKE 明文放行，并禁止访问未授权的 DMZ 区域。** 它展示的核心思想是：**安全策略不应一刀切，而应根据协议、端口和地址进行精细的差异化管控。**

5. 学习目标 5：出站与入站流量处理

每个入站 IP 数据包在收到之后 及 将数据包内容传递到上层（如 TCP、UDP）之前，交由 IPsec 处理。

5.1 出站数据包

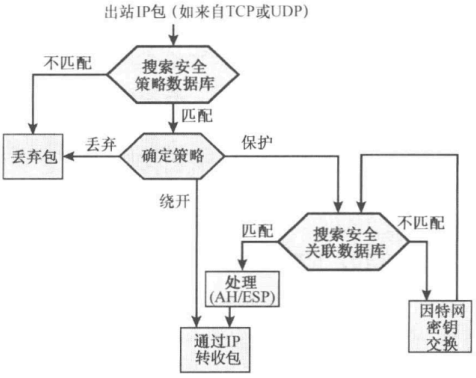


图 20.2　出站数据包的处理模型

图 20.2 出站数据包的处理模型

1. IPsec 用数据包选择器查询 SPD。
2. 没有匹配项时丢弃并报告错误。
3. `bypass` 直接转发；`discard` 丢弃；`protect` 继续查找或建立 SA。
4. 若 SAD 中没有匹配 SA，则调用 IKE 建立带密钥的新 SA。

5. 按 SAD 规定执行 ESP/AH、加密/认证以及传输/隧道封装，再发送数据包。

5.2 入站数据包

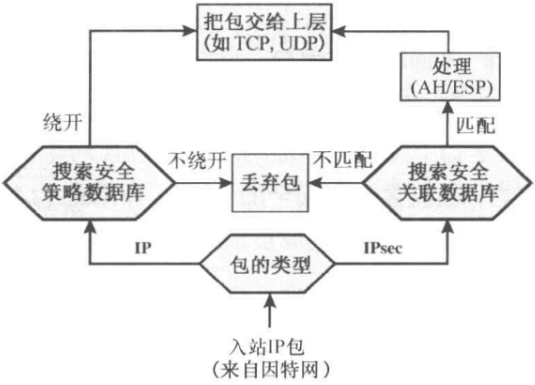


图 20.3　入站数据包处理模型

图 20.3 入站数据包处理模型

1. 根据 IPv4 的协议字段或 IPv6 的下一个头部识别普通、ESP 或 AH 数据包。
2. 普通数据包查询 SPD；只有策略允许 bypass 时才剥离 IP 头部并交给上层，否则丢弃。
3. 安全数据包根据 SPI 查询 SAD；找不到 SA 时丢弃，否则执行认证、反重放、解密和解封装。
4. 处理完成后剥离 IPsec 头部，并把恢复的净荷交给 TCP、UDP 等上层协议。

6. 学习目标 6：封装安全净荷 ESP



图 20.4　ESP 数据包格式

图 20.4 ESP 数据包格式

ESP 顶层格式包含：SPI、序号、净荷数据、填充、填充长度、下一个头部和可选的完整性检查值（ICV）。需要同步时可在净荷开头显式携带 IV；隧道模式还可增加流量保密性填充。

`Payload Data`、`Padding`、`Pad Length` 和 `Next Header` 由 ESP 加密；若选取完整性服务，ICV 在加密后计算，覆盖 ESP 头部和密文但不覆盖 ICV 自身。组合认证加密算法可把完整性标签编码在密文结构中。

填充有三种作用：满足分组密码的块长要求，使填充长度和下一个头部在 32 位字中右对齐，以及隐藏真实净荷长度。ESP 可提供保密性、数据源认证、无连接完整性、反重放和有限流量保密性。

> 这里的"右对齐"是指数据的低位地址端（即数据块的尾部）

6.1 反重放

> **有关窗口、标记等的理解**
>
> 专题笔记： IPsec 反重放机制

重放攻击是指敌手获得一个经过认证的数据包后，在某个时刻将其传送到目的站点的行为。重复接收经过认证的 IP 数据包可能会以某种方式中断服务，或者产生无法预料的后果。"序号"字段可以防止这类攻击。

发送方在新 SA 上将序号计数器置为 0，第一帧使用 1；序号达到 $2^{32}-1$ 时不能回绕，应终止 SA 并重新协商。接收方维护默认大小 $W=64$ 的滑动窗口，右边缘为当前最大合法序号 N。窗口内的新序号先验证完整性再标记，窗口右侧的新序号通过验证后推进窗口，窗口左侧或认证失败的数据包丢弃并记录。

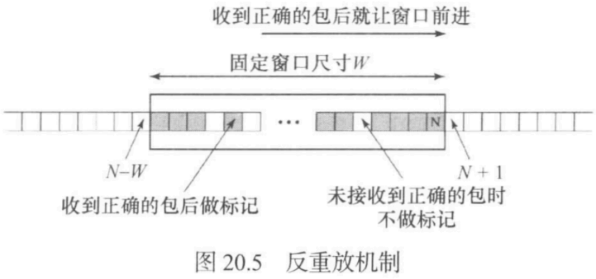


图 20.5　反重放机制

图 20.5 反重放窗口

7. 学习目标 7：组合安全关联

单个 SA 只能实现 AH 或 ESP，不能同时实现两者；需要多种服务时使用 SA 束。两种组合方法是：

- **传输邻接**：在同一 IP 数据包上依次使用多个传输协议，例如内部 ESP、外部 AH；通常只进行一级组合。
- **隧道迭代**：通过多个 IP 隧道嵌套安全协议，隧道可在不同 IPsec 节点终止。

认证和保密性的顺序也影响语义。ESP 自带认证通常是"加密后认证"；内部 AH 传输 SA 加外部 ESP 隧道 SA 可实现"认证后加密"，既隐藏认证数据，又能在目的端取得内部认证结果。

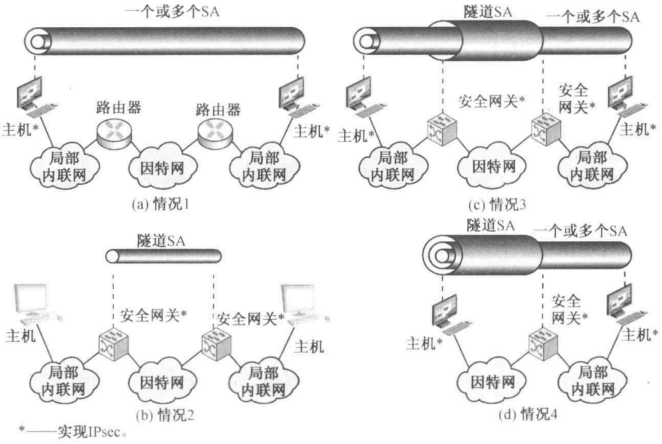


图 20.10　安全关联的基本组合

图 20.10 安全关联的基本组合

四种基本部署包括：主机到主机的端到端 SA；仅网关间的隧道 VPN；网关隧道上再增加端到端保护；以及远程主机通过隧道访问企业防火墙后的系统。

8. 学习目标 8：因特网密钥交换 IKE

> **IKE 目的及理解**
>
> 在 IPsec 中，**密钥交换（IKE）的核心输出是安全关联（SA）**。SA 是一组定义了"用何种算法、何种密钥来保护何种流量"的参数。IKE 本身并不直接加密业务数据，而是为 ESP/AH 这类数据面协议**提供必要的安全上下文**。一旦 SA 建立并安装，ESP/AH 就会接管数据流量的保护工作。
>
> 因此，可以理解为：**IKE 用于交换并建立 SA，通过这些 SA，ESP/AH 协议得以建立并维持一个稳定的、受保护的通信通道，用于传输实际的业务数据。**

8.1 IKE 与 Diffie-Hellman 改进

IPsec 自动密钥管理以 IKE 为主。IKEv1 的体系包括 Oakley 密钥确定协议和 ISAKMP 框架；IKEv2 将两者整合为协议规范。IKE 基于 Diffie-Hellman，但增加 cookie、随机数、参数协商和身份认证：

- cookie 依赖通信双方地址、端口和本地秘密，可验证而无需保存，从而抵御伪造源地址造成的阻塞攻击；
- nonce 防止重放并参与密钥和认证计算；
- 对等方可协商 DH 参数组并交换 DH 公钥；
- 数字签名、公钥加密或对称密钥可认证交换，防止中间人攻击。

Diffie-Hellman 的共享密钥为

$$K = (Y_B)^{X_A} \bmod q = (Y_A)^{X_B} \bmod q = \alpha^{X_A X_B} \bmod q$$

8.2 IKEv2 交换

IKEv2 的初始交换包含两对消息。第一对协商算法、nonce 和 DH 值，建立保护后续 IKE 消息的 IKE SA；第二对在加密信道中交换标识和认证数据，建立第一个用于普通通信的 IPsec SA。因此建立首个数据 SA 需要 4 条消息。 CREATE_CHILD_SA 可建立或重新协商更多子 SA，信息交换用于通知、错误和管理。



图 20.11　IKEv2 交换

图 20.11 IKEv2 交换

IKE 头部包含发起者/响应者 SPI、下一个净荷、版本、交换类型、标志、消息 ID 和总长度。

通用净荷头部——本质是一个类型标识符——用下一个净荷字段串联多个净荷（在一条 IKE 消息中，如果包含多个净荷，如一个 SA 建议、一个密钥交换数据、一个 Nonce，它们会按顺序排列），并用临界位指示未知净荷应跳过还是拒绝。

主要净荷包括 SA 建议、密钥交换、标识、证书/证书请求、认证、nonce、通知、删除、厂商标识、流量选择器、加密、配置和 EAP。

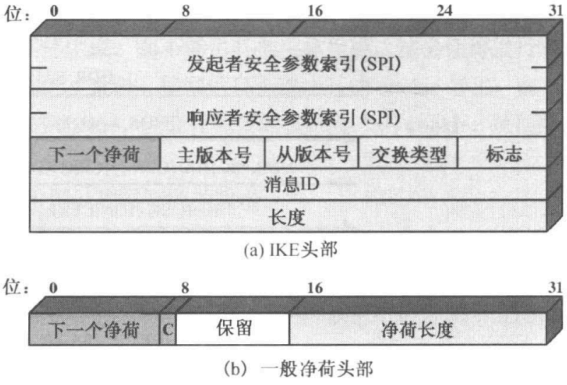


图 20.12　IKE 格式

图 20.12 IKE 格式

9. 学习目标 9：适合 IPsec 的密码学套件

IPsec 需要为不同 SA 选择加密、完整性、伪随机函数、密钥交换和认证算法。教材强调算法套件可协商且应随安全要求、实现能力和生命周期更新。

功能	典型选择或要求
加密	AES 等现代分组密码；可使用认证加密模式如 GCM。
完整性/认证	基于 HMAC 的算法，或认证加密算法内置的完整性标签。
密钥交换	Diffie-Hellman 及椭圆曲线 Diffie-Hellman 参数组。
伪随机函数	IKE 用于从共享秘密、nonce 和上下文派生密钥材料。
身份认证	数字签名、公钥加密或预共享对称密钥。

IPsec 的安全性来自算法、密钥、SA 参数、策略选择和密钥生命周期的共同约束；只启用强算法而错误配置 SPD、SAD、身份认证或反重放窗口，仍不能形成有效保护。

本章关键术语整理

术语	核心含义
IPsec	在 IP 层提供访问控制、认证、完整性、保密性和密钥管理的协议体系。
AH	IPsec 的认证头部协议，提供认证和完整性。
ESP	封装安全净荷协议，提供加密及可选认证、完整性和反重放。
SA	单向、带安全参数的逻辑连接。
SPI	在 AH/ESP 中标识 SA 的 32 位索引。
SAD	保存各 SA 算法、密钥、序号和生命周期参数的数据库。
SPD	按流量选择器决定 bypass、discard 或 protect 的策略数据库。
传输模式	保护 IP 净荷、用于端到端通信的 IPsec 模式。
隧道模式	将整个内部 IP 数据包封装保护的 IPsec 模式。
反重放窗口	用序号和滑动窗口拒绝重复或过旧数据包的机制。
SA 束	为同一流量组合的一系列安全关联。
IKE	协商 IPsec 参数、认证对等方并建立 SA 的密钥管理协议。
IKE SA	保护后续 IKE 控制消息的安全关联。
VPN	在公共网络上使用隧道和安全关联构造的虚拟专用网络。
nonce	防止重放并参与密钥派生的随机值。

学习目标自检

1. 能否说明 IPsec 的应用、文档组成和六类主要安全服务？
2. 能否比较 ESP 传输模式和隧道模式的保护范围、端点和 VPN 用途？
3. 能否解释 SA 的单向性、SPI/目的地址/协议三元组和生命周期参数？
4. 能否区分 SAD 保存的运行参数与 SPD 保存的流量策略和选择器？
5. 能否按顺序描述 IPsec 对出站和入站数据包的处理？
6. 能否写出 ESP 字段、加密范围、ICV 计算顺序、填充用途和反重放窗口逻辑？
7. 能否比较传输邻接、隧道迭代和四种基本 SA 部署组合？
8. 能否解释 IKE cookie、nonce、DH、认证方法、IKE SA 和 CREATE_CHILD_SA 的作用？

9. 能否按用途选择并比较 IPsec 的加密、完整性、PRF、密钥交换和认证套件？